

Threat Model

Update: RBAC enforcement, internal service port exposure, leaked git history, the Wazuh Indexer credential mismatch, and the host firewall have all been remediated since this model was first written see Document 8 for the full log. Items below are annotated **FIXED** where closed.

1. Scope & Trust Zones

Covers the platform end-to-end: edge (Traefik), application layer, the security monitoring stack, case management/automation, the AI layer, and data stores — analyzed with STRIDE (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege) against each boundary.

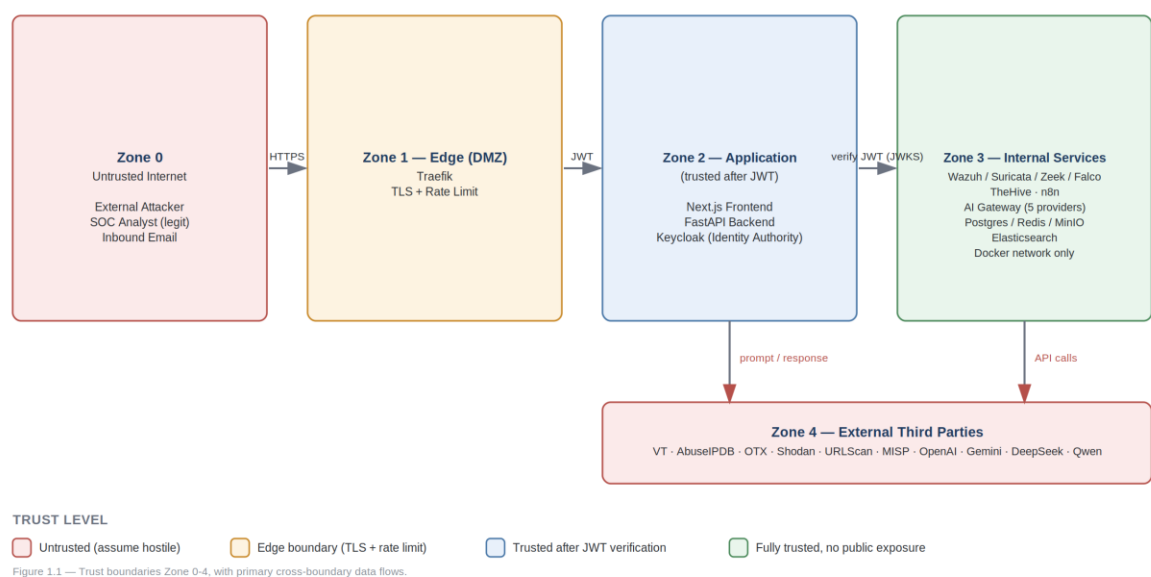


Figure 1.1 — Trust boundaries Zone 0-4, with primary cross-boundary data flows.

Zone	Contains	Trust Level
0 — Untrusted	Internet, unauthenticated visitors, inbound email	None — assume hostile
1 — Edge	Traefik	Enforces TLS + rate limiting; untrusted for payload content
2 — Application	Next.js, FastAPI backend, Keycloak	Trusted only after JWT verification per request
3 — Internal Services	Postgres, Redis, MinIO, Elasticsearch, Wazuh, Suricata, Zeek, Falco, TheHive, n8n, AI Gateway	Trusted, no public exposure
4 — External Third Parties	VirusTotal, AbuseIPDB, OTX, Shodan, URLScan, MISP, OpenAI/Gemini/DeepSeek/Qwen	Untrusted destinations — data leaves the perimeter

2. Key Assets

Asset	Why it matters
Keycloak signing keys / JWTs	Compromise = impersonate any analyst or the backend across every endpoint
External TI & AI provider API keys	Financial/quota abuse, or a pivot point to exfiltrate via the platform's own credentials
PostgreSQL sop_db	System of record for all indicators, assets, orgs, alerts
MinIO evidence/reports/samples bucket	May contain malware samples and generated executive reports
n8n workflow & credentials	Full mailbox access + ability to send authenticated emails/Slack messages as the platform
Wazuh/Suricata/Zeek/Falco raw logs	Detailed internal network/host activity — a map of the environment for an attacker

3. STRIDE Analysis by Trust Boundary

3.1 Internet → Traefik (Zone 0→1)

Threat	Sev	Mitigation
HTTP flood against public endpoints	Med	Rate-limit middleware (50 avg/100 burst) on the backend router — not yet on frontend/n8n routers
Traefik dashboard exposed (--api.insecure=true, port 8081)	High	Disable insecure API mode or bind to VPN/localhost
Internal services reachable directly on the VPS public IP	FIXED	Host ports removed from compose; ufw default-denies incoming except 22/80/443

3.2 Inbound Email → n8n

Threat	Sev	Mitigation
Crafted email breaks the IOC regex / injects content downstream	Med	Sanitize input before AI Summary / Slack steps
Spoofed sender triggering false threat reports	Low	Restrict IMAP trigger to a known mailbox or SPF/DKIM verification

3.3 Identity & Session (Keycloak/JWT)

Threat	Sev	Mitigation
Forged JWT / algorithm confusion	High	Backend pins algorithms=["RS256"], validates issuer + audience — blocked
Role tampering for elevated privileges	Med	require_role() reads only server-verified realm_access.roles
No audit trail of which analyst performed an action	Med	Add user-attributed audit logging (JWT already carries the identity)
Keycloak in start-dev with default admin creds	High	Rotate credentials, disable dev mode before production

3.4 Backend API

Threat	Sev	Mitigation
Any authenticated user can call any endpoint	Med — partial	require_role("analyst") applied to asset/org delete; extend to remaining destructive endpoints
Verbose error bodies ({"error": str(e)})	Med	Aids debugging but may leak internals — sanitize external-facing errors
/ws/alerts accepts a token via query string	Low	Verified server-side; query-string tokens can leak into logs — accepted risk

3.5 AI Layer

Threat	Sev	Mitigation
Threat data sent to third-party AI providers	Med	Acceptable per provider terms; strict-residency orgs should default to local Ollama
Prompt injection via attacker-controlled fields	Med	No sanitization yet — add input length limits + prompt hardening

3.6 Internal Services

Threat	Sev	Mitigation
Elasticsearch runs with xpack.security.enabled=false	High	Acceptable only while network is non-public; enable X-Pack security before multi-tenant use
n8n admin UI on default basic-auth creds	Med — reduced	ufw + Traefik-only routing now blocks direct-IP access; credential still needs rotation
Default/weak creds across Postgres, MinIO, Grafana, Wazuh	High	All flagged for rotation (Document 7); not publicly routed today, limiting exposure

4. Priority Remediation Summary

See Document 8 for the full step-by-step remediation log. Remaining highest-priority items before production/customer-facing use:

- Still pending: rotate every default credential and move secrets out of docker-compose.yml into a secrets manager or excluded .env files.
- Disable Traefik's insecure API/dashboard mode or restrict it to a private network.
- Switch Keycloak from start-dev to production mode with a hardened realm + enforced MFA for analysts.
- Enable Elasticsearch security (authentication + TLS).
- Partially done: extend require_role checks to all remaining destructive/administrative endpoints (currently: asset/org deletion only).